

NAESB CYBERSECURITY

PROCUREMENT CONTRACT ADDENDUM PROPOSED STANDARD

DICK BROOKS

NAESB INTERIM CSS CHAIR

Copyright and all other Rights Reserved Business Cyber Guardian ®

KEY PROVISIONS

Section 3 establishes a mandatory vendor cybersecurity program requiring

- **secure by design development practices,**
- **vulnerability management,**
- **rapid incident reporting,**
- **remediation planning, and**
- **coordinated disclosure to protect electric-sector supply chains and Bulk Power System operations**

Five Key Themes

1. **Governance** - Executive-approved cybersecurity policies.
2. **Standards Compliance** - ISO, NIST, and IEC alignment.
3. **Vulnerability Transparency** - Rapid disclosure of security issues.
4. **Remediation Accountability** - Documented plans and status reporting.
5. **Grid Security Protection** - Coordinated disclosure to E-ISAC and CISA

GUIDING PRINCIPLES

- Align with and leverage existing cybersecurity regulations placed on product manufacturers
  - NERC CIP-010
  - NERC CIP-013
  - FERC Order 912
  - Vulnerability Reporting and Supply Chain Risk Management Regulations applicable to product manufacturers:
    - EU CRA
    - CISA CIRCIA
    - NIST Secure Development Framework and the CSF V2.0
    - CISA Secure by Design best practices (SAG)
- DO NO HARM

SETTING VENDOR EXPECTATIONS

Objective: Require vendors to operate a formal cybersecurity program that provides product security transparency, vulnerability management, rapid disclosure, coordinated remediation, and protection of critical electric infrastructure.

Vendor Obligations

- ✅ Maintain officer-approved cybersecurity policies and procedures and provide updates to Product Users when they change.
- ✅ Manage product inventories, version control, and security-related product updates and vulnerability disclosure reports.
- ✅ Align cybersecurity programs with recognized standards including ISO 27001, NIST SP 800-218, IEC 62443-4-1, and IEC 62443-4-2, where applicable.
- ✅ Operate a formal vulnerability detection, assessment, root-cause analysis, and remediation program.
- ✅ Provide product users with a completed Exhibit A (Product List) with a Secure by Design Attestation (Vendor Response File)

VENDOR EXPECTATIONS CONT'D

✅ Report:

- Confirmed exploitable vulnerabilities and severe incidents within **72 hours**
- High-risk vulnerabilities with known exploits **immediately**
- Vendor-identified incidents affecting product security or protected information **immediately**

✅ Provide vulnerability assessments, remediation plans, compensating controls, workarounds, and ongoing status updates for all reported vulnerabilities affecting a product.

✅ Disclose vulnerabilities affecting Bulk Power System and grid operations through coordinated industry channels including E-ISAC and CISA.

Bottom Line

Section 3 establishes a cybersecurity supply-chain accountability framework that requires vendors to continuously identify, disclose, remediate, and communicate product cybersecurity risks and adhere to secure by design best practices set by CISA throughout the product lifecycle, particularly for products supporting critical electric infrastructure.

SECTION 5 – SPECIAL CONDITIONS

- This is where a product users expresses any expectations that are not covered in Section 3
- Here are some good examples of what a product users may specify in Section 5 Special Conditions
  - Vendor MUST NOT perform any automated patching on production systems
  - Vendor MUST promptly deliver all product patches and upgrades to the designated party for testing
  - Vendor NUST provide a method for product user to test product patches and upgrades and deploy approved patches/upgrades in production systems at the product users choosing

RESOURCES

- NAESB CS Addendum proposed standard: https://naesb.org/pdf4/weq_ec102126a2.docx
- NAESB CS Addendum FAQ: https://naesb.org/pdf4/weq_2026_api_1b_rec_091426_attachment2.docx
- Unofficial Historical timeline for the development of this standard: https://www.energycentral.com/intelligent-utility/post/revised-product-cybersecurity-procurement-contract-langauge-for-critical-SM0EnzT70YcFOKp

- Contact me: Dick Brooks, dick@businesscyberguardian.com https://businesscyberguardian.com/
- Contact NAESB: naesb@naesb.org https://naesb.org
- NAESB standards in FERC Regulations: https://www.ecfr.gov/current/title-18/chapter-I/subchapter-B/part-38